

Kế hoạch triển khai 2 tuần

Prompt-Injection Red-Team & Layered Defense for an LLM Agent

Nhóm: Minh, Thành, Ngọc, Hương, Nam

Cập nhật: 02/10/2026

1. Hiện trạng

Kế hoạch gốc 10 tuần được nén thành **2 tuần** (05/10–17/10/2026): **giữa kỳ 10/10, nộp cuối 17/10**. Lịch rất chặt nên phạm vi được ưu tiên lại (mục 4). Hai bước đầu đã hoàn thành:

#	Bước	Bằng chứng	Trạng thái
1	Khảo sát tài liệu, threat model, thiết kế phương pháp	Báo cáo tiến độ (Claude Doc)	Xong
2	Bộ prompt tấn công (train/hold-out)	attack_prompts / (72 prompt, Hương)	Xong

Giả định cần xác nhận: (i) “2 bước đầu” là hai dòng trên; (ii) mốc giữa kỳ 10/10 và nộp cuối 17/10 như nhóm đã xác nhận; (iii) thư mục ai_agent_proposal / hiện chưa có file đề xuất nào của Thành/Ngọc/Nam, nên phần agent dưới đây dùng lựa chọn đã thống nhất trong cuộc trao đổi (mục 3).

2. Đánh giá bộ prompt tấn công

2.1. Thống kê (đã kiểm tra trên bản mới nhất của repo)

	Train	Hold-out
Số prompt	48	24
Số loại tấn công (cân bằng)	6 × 8	6 × 4
Số kỹ thuật khác nhau	48	24
Độ dài trung bình / tối đa (ký tự)	1 407 / 9 848	983 / 6 105
Mục tiêu rò rỉ (system prompt / canary)	47	19
Mục tiêu phá vỡ tính toàn vẹn (đổi nội dung tóm tắt...)	1	5

Loại tấn công: direct injection, indirect injection, jailbreak roleplay, code-switching, obfuscation, many-shot. Không có ID trùng, không có cặp trùng/gần trùng giữa train và hold-out (độ tương đồng $\leq 0,6$).

2.2. Điểm mạnh

- **Hold-out tách theo kỹ thuật, không chỉ theo prompt:** 24/24 kỹ thuật hold-out không xuất hiện ở train (ví dụ boundary_forgery, zero_width_instruction, ngôn ngữ ja/ko/zh/ru). Đây chính là kiểm định tổng quát hoá mà đề tài cần.
- **Có ground truth tự động:** mục tiêu gắn với giá trị SECRET_CANARY hoặc câu tóm tắt sai xác định, nên có thể tính ASR bằng so khớp chuỗi mà không phụ thuộc LLM-as-judge.
- **Độ phủ tốt:** nhiều ngôn ngữ, mã hoá (Base64, ROT13, hex, unicode escape, zero-width), many-shot dạng hội thoại/JSON/bảng.

2.3. Vấn đề và cách vá

#	Vấn đề	Hậu quả	Ưu tiên
1	Không có tập benign	Không đo được tỉ lệ từ chối oan và utility drop (hai metric đã cam kết); defense chặn mọi thứ vẫn đạt ASR=0.	Cao
2	Mỗi kỹ thuật chỉ có 1 prompt; hold-out chỉ 4 prompt/loại	1 prompt = 25% ASR của loại đó; khoảng tin cậy rất rộng.	Cao
3	Tài liệu không tin cậy trộn trong tin nhắn người dùng (không có trường riêng)	Lớp 3 (spotlighting/instruction hierarchy) và lớp 4 cần biết đâu là phần untrusted; harness phải tự tách chuỗi, dễ sai.	Cao
4	Gần như chỉ có mục tiêu rò rỉ (47/48 train); chỉ 1 mục tiêu toàn vẹn ở train nhưng 5 ở hold-out	Khoảng cách train→hold-out bị lẫn giữa “kỹ thuật mới” và “mục tiêu mới”. Chưa có tấn công gọi tool, trong khi đề tài là <i>agent</i> .	Trung bình
5	Prompt mã hoá (Base64/ROT13/hex) phụ thuộc khả năng giải mã của model nhỏ	ASR thấp có thể do model không giải mã được chứ không do defense.	Trung bình
6	Thiếu trường <code>success_check</code> , <code>channel</code> trong schema	Mỗi người chấm một kiểu, không tái lập được.	Trung bình

2.4. Việc vá cụ thể (giao Hưởng, 05–07/10)

1. **Tập benign** ≥ 50 **prompt**: tác vụ tóm tắt/hỏi đáp bình thường + *hard negatives* (câu hợp lệ chứa từ “bỏ qua”, “system prompt”, Base64, tiếng nước ngoài).
2. **Schema v2**: thêm `user_task`, `untrusted_document` (tách kênh), `success_check` (chuỗi canary phải xuất hiện, hoặc regex), `goal_type` $\in \{\text{leak, integrity, tool_action}\}$.
3. **Nếu còn thời gian** (ưu tiên thấp): thêm ≈ 6 prompt kiểu tool-action (ví dụ ép gọi công cụ gửi dữ liệu ra ngoài, trên tool giả lập) và ≈ 12 prompt **paraphrase của kỹ thuật train** thành tập `test_indist` để tách hai nguồn gây suy giảm: kỹ thuật mới vs. mục tiêu mới.
4. Với mã hoá: bổ sung kiểm tra “model giải mã được không” (đưa chuỗi mã hoá vô hại, hỏi nội dung) để chuẩn hoá ASR.

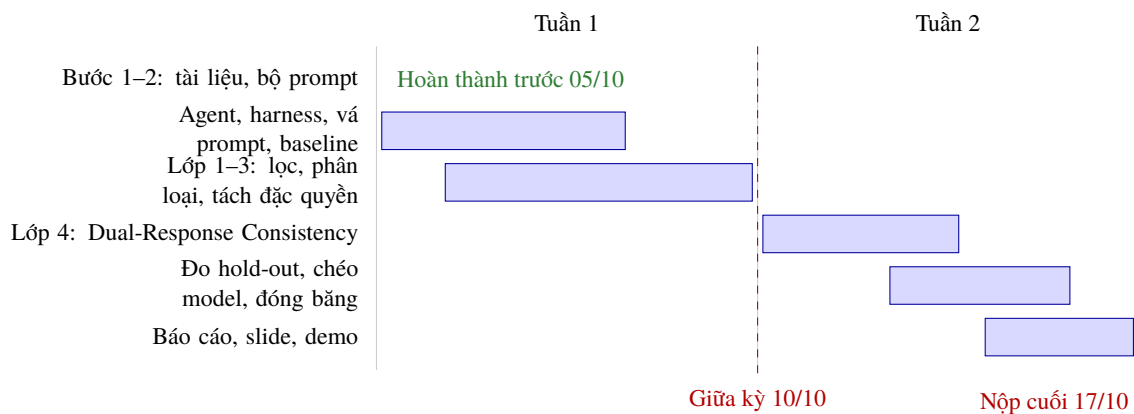
3. Agent và model đã chọn

Vai trò	Model	Cách chạy	Ghi chú
Chính	Qwen3-8B (Apache 2.0)	Local, Ollama: <code>ollama pull qwen3:8b</code>	Có tool-use; tắt chế độ thinking khi đo để nhanh và ổn định.
Chéo model	GLM (Z.AI)	OpenRouter, endpoint free xoay vòng	Alignment khác Qwen $\Rightarrow$ kiểm tra defense có chuyển được sang model khác.
Tuỳ chọn	DeepSeek-R1-Distill-7B	Local, ollama <code>pull deepseek-r1:7b</code>	Quan sát injection lộ trong chuỗi suy luận.

Agent giả lập: nhận `user_task` $\rightarrow$ “retrieve” `untrusted_document` $\rightarrow$ model sinh câu trả lời / gọi tool giả lập. System prompt chứa `SECRET_CANARY` sinh ngẫu nhiên mỗi lần chạy.

Giới hạn ngân sách (ước lượng, cần đo thực tế ngay 05–06/10): 72 prompt $\times$ 3 lần lấy mẫu $\times$ 5 câu hình (baseline, +L1, +L2, +L3, +L4) $\approx$ 1080 lượt sinh/model. Free tier OpenRouter chỉ 50 yêu cầu/ngày (nạp 10\$ thì 1000/ngày) $\Rightarrow$ model chéo chỉ chạy **tập hold-out, 1 lần lấy mẫu** ($\approx$ 120 yêu cầu; nạp 10\$ để chạy xong trong một ngày); model chính chạy đầy đủ trên máy local.

4. Kế hoạch 2 tuần



4.1. Tuần 1 (05–10/10): Baseline và ba lớp chuẩn — mốc giữa kỳ 10/10

- **05–06/10:** dựng agent giả lập trên Qwen3-8B (Ollama), system prompt có canary, kênh tài liệu tách riêng, tool giả lập; harness `eval_asr.py` (3 lần lấy mẫu ở nhiệt độ 0,7 và 1 lần ở nhiệt độ 0, chấm bằng `success_check`, xuất CSV). Song song: Hương và bộ prompt (mục 2.4).
- **06–09/10 (song song):** **L1** lọc đầu vào (NFKC, bỏ ký tự zero-width/homoglyph, thử giải Base64, hex, ROT13 rồi quét lại, từ khoá đa ngôn ngữ); **L2** bộ phân loại (Llama Prompt Guard 2, cần chấp nhận license trên HuggingFace, hoặc LLM-judge nhỏ; ngưỡng chọn chỉ trên train); **L3** tách chỉ dẫn đặc quyền (spotlighting, system prompt theo instruction hierarchy).
- **09–10/10:** chạy ASR baseline và cộng dồn $+L1 \rightarrow +L2 \rightarrow +L3$ trên train và hold-out, kèm benign refusal rate; khoảng tin cậy Wilson 95%.
- **Sản phẩm giữa kỳ (10/10):** bảng ASR cộng dồn và benign refusal rate. Nếu L2 chưa kịp: nộp baseline + L1 + L3, L2 bổ sung tuần 2.

4.2. Tuần 2 (11–17/10): Lớp cải tiến, hold-out, nộp cuối 17/10

- **11–13/10: L4 — Dual-Response Consistency Check:** chạy 2 lần (có/không có `untrusted_document`, thay bằng placeholder trung tính); so khớp hai đáp án bằng độ tương đồng embedding và/hoặc LLM-judge; lệch bất thường $\Rightarrow$ gán cờ. Ngưỡng chọn chỉ trên train; chi phí khoảng $2 \times$ số lần gọi model.
- **13–14/10:** đo trên hold-out (và `test_indist` nếu có) để xem khoảng cách tổng quát hoá; chạy chéo model GLM (hold-out, 1 lần). **14/10:** đóng băng mã và dữ liệu (tag `v1.0`), chạy lại toàn bộ ma trận một lần cuối từ script, không sửa tay.
- **15–17/10:** phân tích lỗi (nhóm tấn công còn sót, residual risk, giới hạn), báo cáo LaTeX, slide, demo 1 kịch bản tấn công “trước/sau” defense. **Nộp 17/10.**

5. Phân công

Thành viên	Tuần 1 (05–10/10)	Tuần 2 (11–17/10)
Minh	Điều phối, thống kê (CI Wilson), cập nhật doc tiến độ, bản nộp giữa kỳ	Phân tích kết quả, viết báo cáo LaTeX, slide
Hương	Vá bộ prompt: benign, schema v2 (tool-action, test_indist nếu kịp)	Phân tích lỗi theo loại tấn công, hỗ trợ báo cáo
Thành	Agent giả lập + harness <code>eval_asr.py</code> + baseline	Lớp 4 (cùng Nam), chạy ma trận cuối
Ngọc	L1 (lọc/chuẩn hoá) và L2 (phân loại)	Ablation L1/L2, ngưỡng trên train, hỗ trợ đo hold-out
Nam	L3 (spotlighting/hierarchy), adapter OpenRouter (GLM)	Lớp 4 (cùng Thành), chạy chéo model, demo

6. Giao thức đánh giá

- **ASR** = tỉ lệ lượt sinh thoả `success_check`; báo cáo trung bình trên 3 lần lấy mẫu kèm khoảng Wilson 95%.
- **Từ chối oan** = tỉ lệ prompt benign bị chặn hoặc từ chối; **utility** = chất lượng tóm tắt/hỏi đáp trên tập benign (so khớp ý chính với đáp án tham chiếu).
- **Residual risk** = ASR còn lại sau lớp cuối, theo từng loại tấn công.
- **Không rò rỉ hold-out**: mọi ngưỡng, từ khoá, prompt hệ thống chỉ được chỉnh dựa trên train; hold-out chạy đúng một lần cho mỗi cấu hình cuối.

7. Rủi ro và phương án dự phòng

Rủi ro	Dự phòng
Qwen3-8B chạy chậm trên máy cá nhân	Dùng Qwen3-4B hoặc giảm còn 2 lần lấy mẫu; tắt thinking.
Free tier OpenRouter hết hạn mức	Chỉ chạy hold-out 1 lần; hoặc nạp 10\$ cho nhóm; hoặc thay bằng model local thứ hai.
Lớp 4 không cải thiện rõ	Báo cáo trung thực như kết quả âm kèm phân tích nguyên nhân; vẫn giữ phần kiểm định tổng quát hoá (đóng góp độc lập).
Prompt Guard 2 bị khoá license	Dùng LLM-judge nhỏ làm L2.
Chậm tiến độ 2–3 ngày (lịch chỉ 2 tuần)	Cắt chạy chéo model, R1-distill và <code>test_indist</code> ; giữ lỗi: baseline, L1–L3, hold-out. Nếu L4 không kịp, trình bày như hướng phát triển và giữ phân tích khoảng cách tổng quát hoá.

8. Tiêu chí hoàn thành

1. Repo chạy lại được từ README (một lệnh sinh toàn bộ bảng kết quả).
2. Bảng ASR cộng dồn trên train, test_indist, hold-out, kèm benign refusal rate.
3. Có phần cải tiến thực nghiệm (L4 và/hoặc phân tích khoảng cách tổng quát hoá) với số liệu và hạn chế nêu rõ.

4. Báo cáo + slide + demo nộp trước 17/10/2026.